

Citadel

UPI Scam-Sequence Shield

AI made the scam lure perfect. It did not change what the payment looks like at the moment of harm. Citadel watches the scam sequence and steps in at step 3 of 4, before the money moves, with a graded response instead of block/allow.

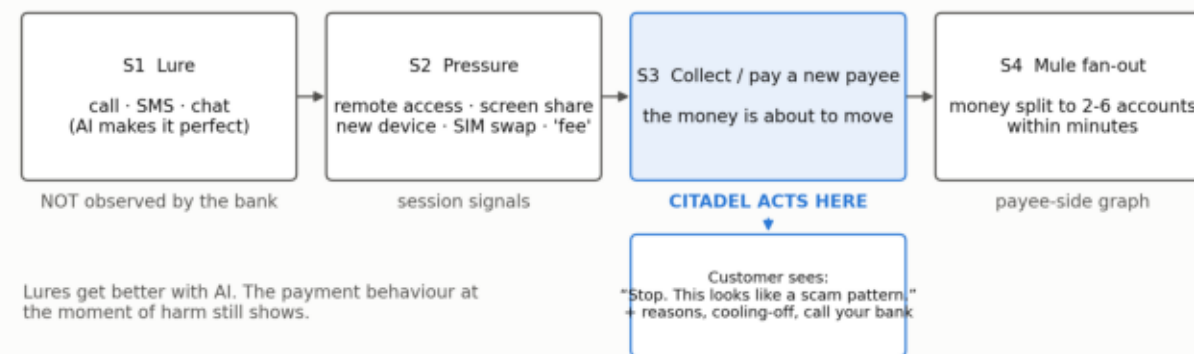
RAKSHAM AI Cybersecurity Hackathon · Problem Statement 2: AI-driven scam pattern recognition

[Team name] · [members]

One person, one moment, one bounded problem

- Primary user: the customer at the UPI approval screen — focus on first-time and senior users, who are targeted by refund, 'bank support', KYC and QR scams.
- Secondary user: the PSP / bank fraud analyst who reviews held payments.
- The harmful moment: approving a collect request or paying new payee. Seconds later a mule splits the money across several accounts and UPI payments are usually irreversible.
- Why lure detection is not enough: generative AI makes calls, SMS and chats fluent and endlessly varied. The lure (step 1) is also invisible to the bank.
- What does not change: a new payee, an unusual amount, a remote-control app, a rushed approval, and a payee that collects from strangers and pays straight out.

A scam is a sequence, not a transaction



Six scam scripts, six evasions — declared as data

V1 Fake-refund collect request

A caller says a refund or cashback is due and sends a UPI collect request; the victim enters the PIN believing it receives money. Approving a collect SENDS money.

V2 Screen-share "bank support" scam

A fake bank or wallet support agent asks the victim to install a screen-sharing or remote-control app "to fix a blocked account", then walks them through paying a new payee.

V3 Fake-KYC link, then payment

An SMS says the account will be blocked unless KYC is updated. The link leads to a "verification fee" and then a larger payment; some victims re-register UPI on a new device on the scammer's instructions.

V4 QR "scan to receive money"

A fake buyer on a marketplace sends a QR code "to receive payment". Scanning and entering the PIN PAYS the scammer. QR codes are only ever for paying.

V5 Utility / courier disconnection threat

A call or SMS says electricity will be cut tonight or a parcel is held unless a small dues payment is made now; small amounts, urgency, often split across attempts.

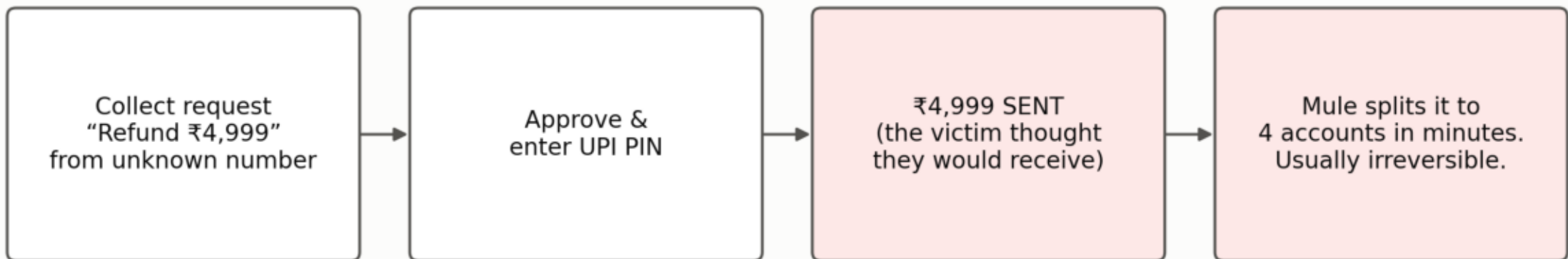
V6 Task / job scam

A "work from home" task pays small rewards first, then demands growing deposits to "unlock" earnings, each to a different account.

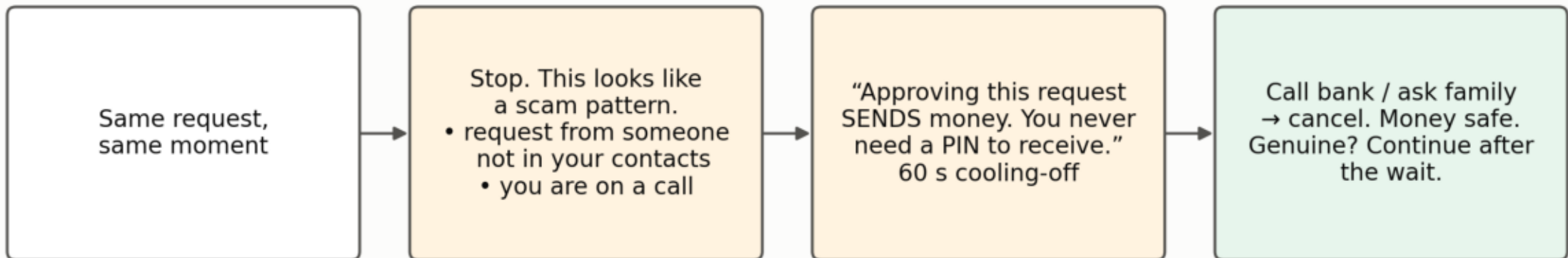
Evasions: amount splitting · slow-drip pacing · aged/recruited mule · payee-name mimicry · time-of-day mimicry · signal suppression. Every signal fires probabilistically; the attacker can only pull attacker-controlled levers. One whole variant (V4) and one evasion (signal_suppression) are never shown to the model.

Before and after: the same scam, the same moment

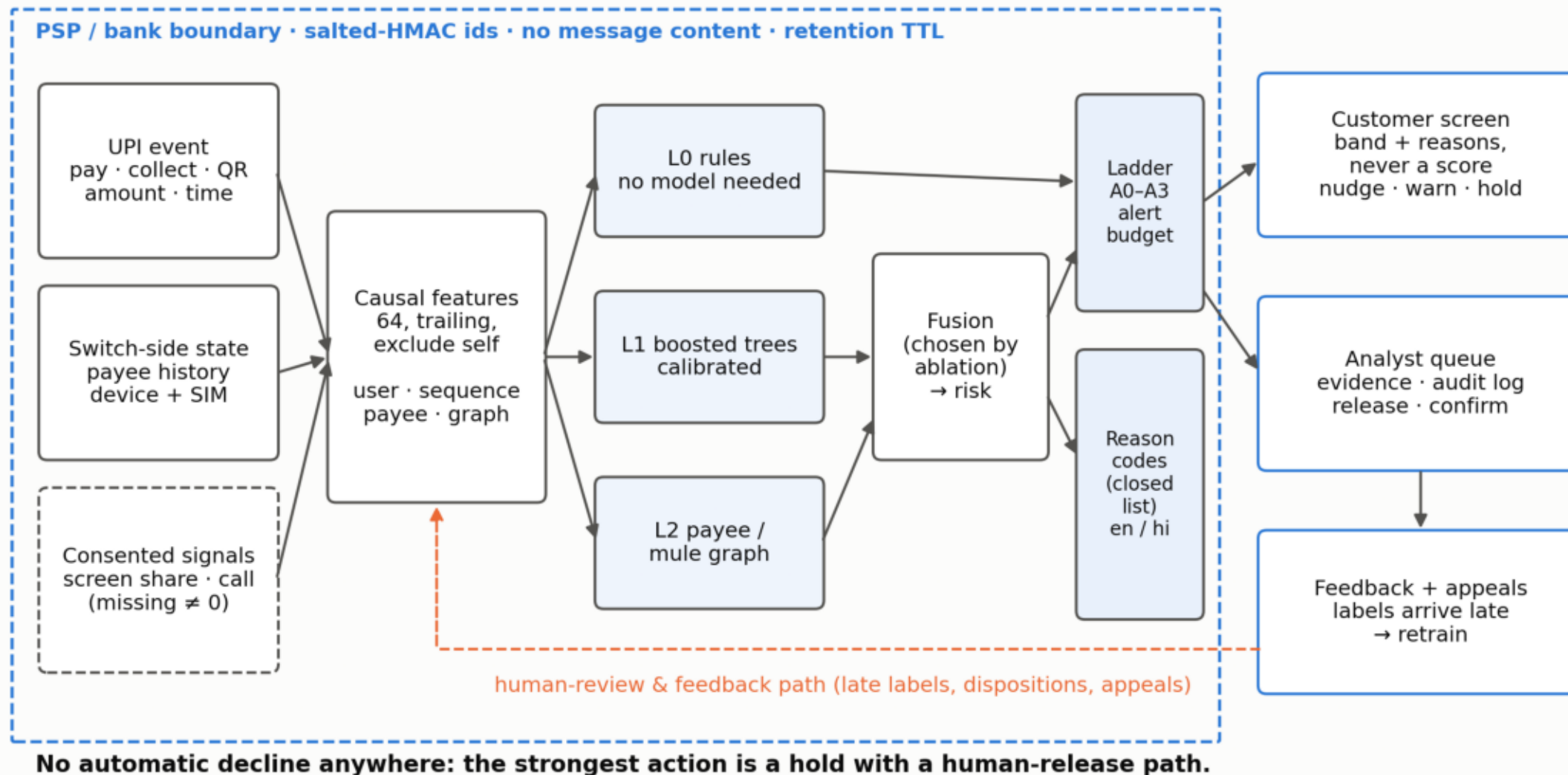
Without Citadel



With Citadel

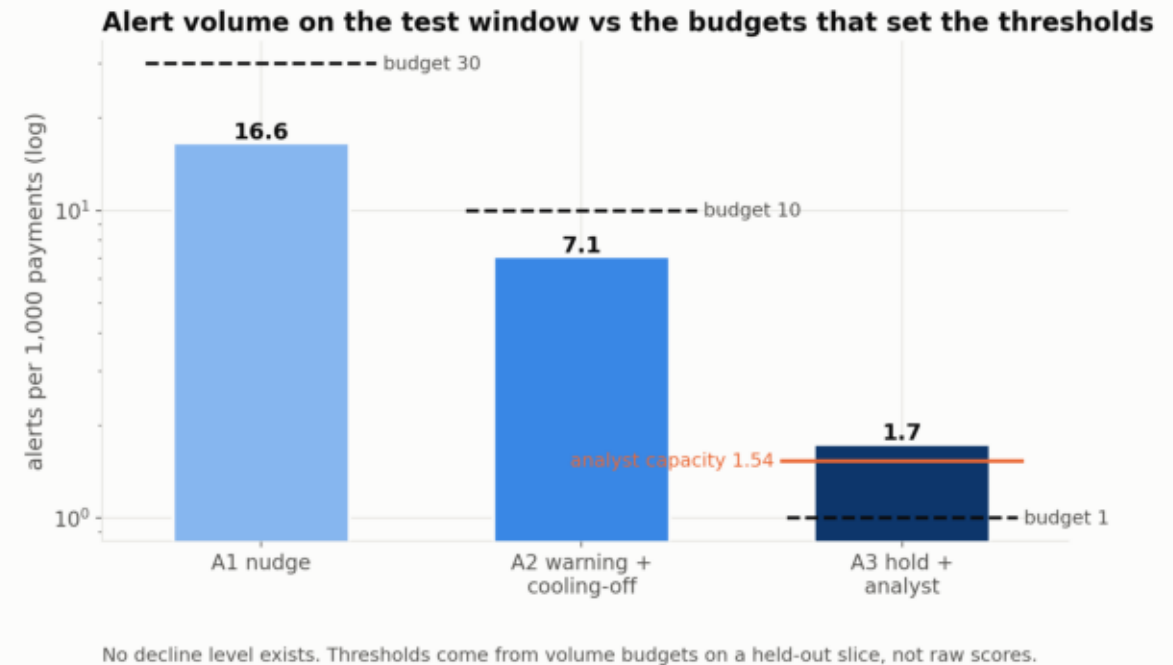


Three layers that fail differently, one graded response



Sequence, payee and graph signals, with readable reasons

- 64 causal features: every window is trailing and excludes the payment being scored (tested against brute-force references and a prefix-invariance test).
 - user baseline: amount vs the customer's own history, usual hour, usual payment type
 - sequence: anomaly then new payee, split bursts, fast collect approvals, credits from strangers
 - payee: fan-in from strangers, pass-through, account age; graph: hops to confirmed mules, shared handsets
- L0 rule cards (no model needed; zero false positives on every legitimate population by test) can only add friction. L1 boosted trees and L2 payee graph are fused by the rule that won on a held-out slice.
- Ladder thresholds come from volume budgets (warnings $\leq 1\%$, holds $\leq 0.1\%$ of payments), not raw scores.
- Every alert carries 1-3 codes from a closed list of 15, shown only when literally true; generic fallback on 2.7% of alerts.



Preliminary validation (synthetic data — an upper bound)

Scam payments warned or held at the deployed ladder

77.1%

(95% CI 72.9%–80.8%)

Episodes stopped at or before the first harmful payment

76.3%

(95% CI 69.4%–82.1%)

Recall at a 0.5% false-positive rate

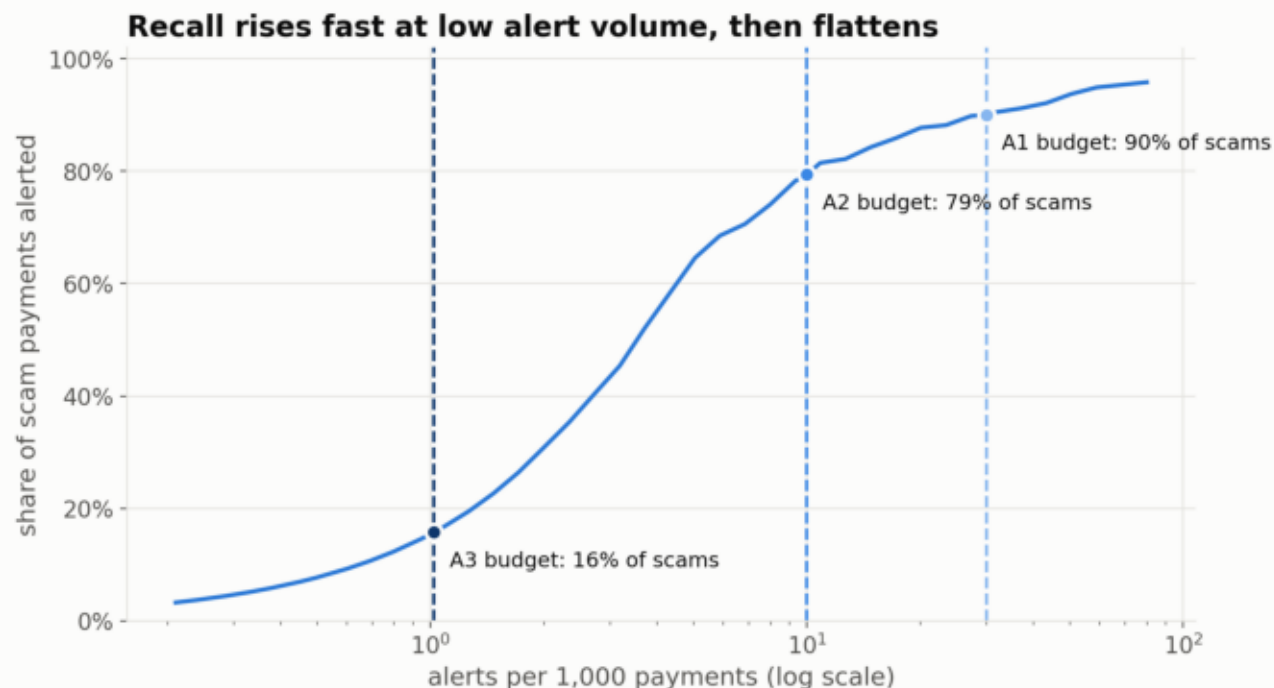
80.1%

(95% CI 76.1%–83.6%)

PR-AUC (118x the base rate of 0.65%)

0.767

(95% CI 0.725–0.801)



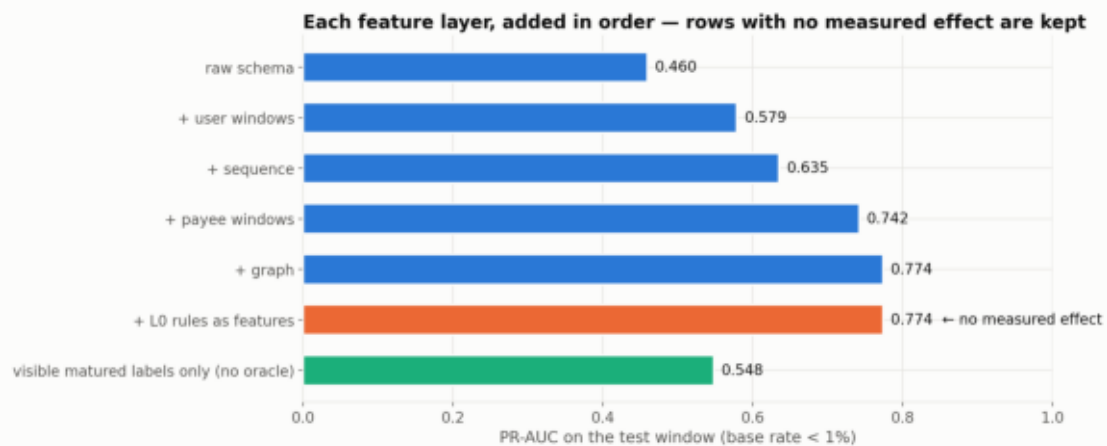
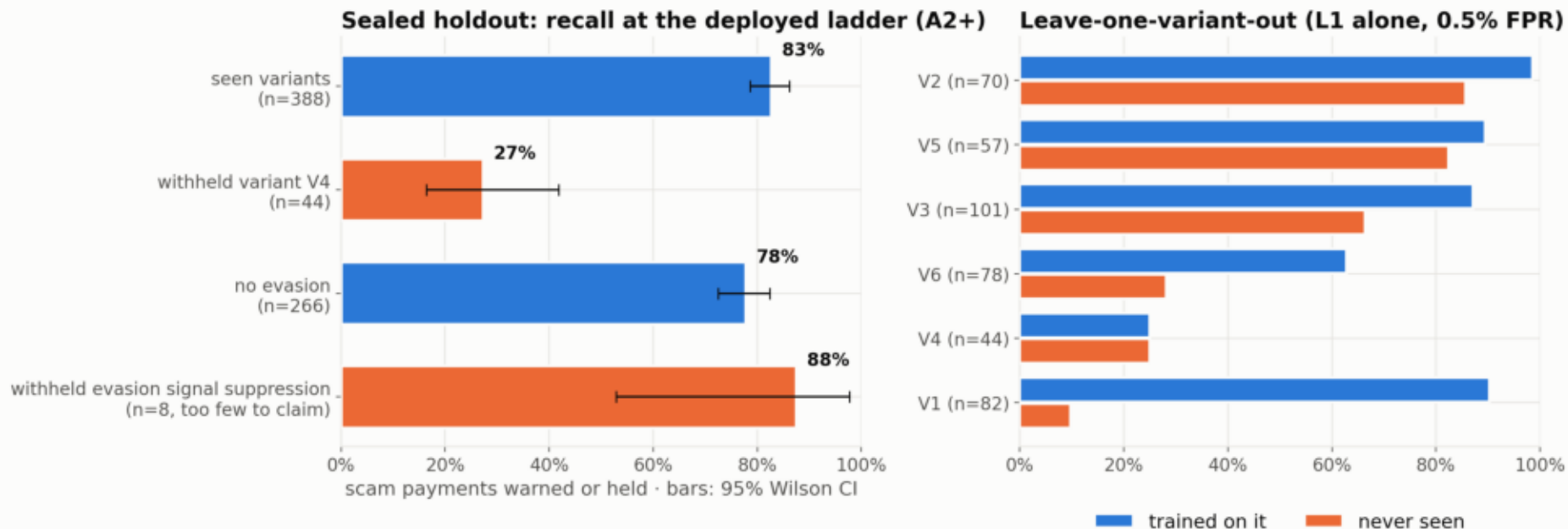
- Test window: 66,615 payments, 432 scam payments; time-forward split with purge and embargo, no random splits.

- Alert load: 8.8 warnings and 1.74 holds per 1,000 payments.

- Same rows, same budget: 'first-time payee' rule 3.2%, ten expert rules 4.6%, logistic regression 47.5% recall at 0.5% FPR.

- Data sanity: best single column AUC 0.730 (gate 0.95); separability probe 83.6% (flag at 92%).

What it has never seen — and what did not help



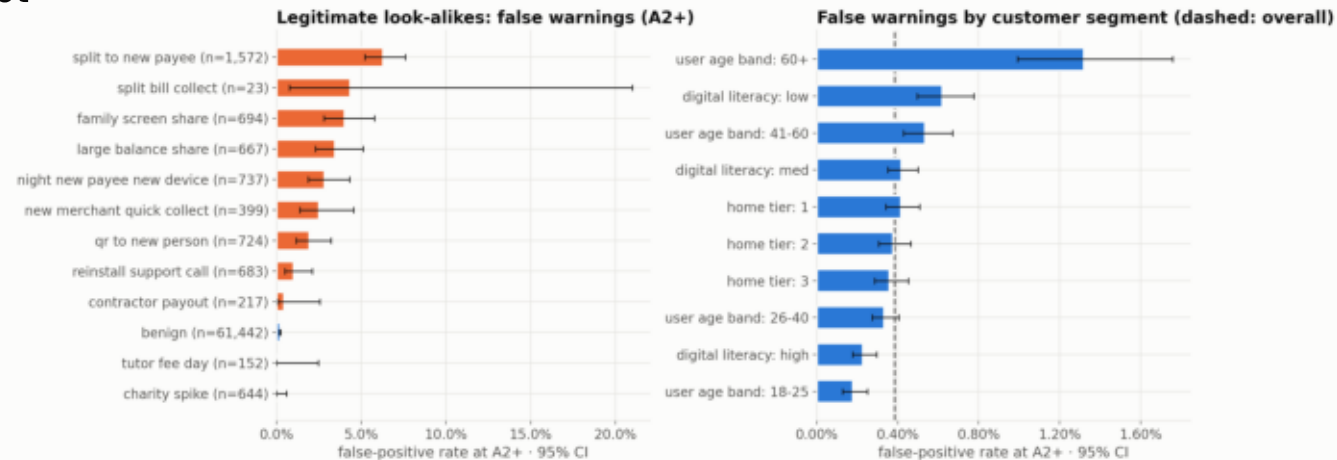
• Withheld variant: 27.3% (95% CI 16.3%–41.8%, n=44) vs seen 82.7% (95% CI 78.7%–86.2%, n=388). Generalisation to an unseen script is the main weakness; the finale adds scripts through the Scam Studio and re-measures.

• Raw columns alone: PR-AUC 0.460; all layers 0.774. Rows with no measured effect are kept.

• Fusing L2 + isolation forest over L1 alone: no measured effect.

Safety, privacy and responsible AI

- No automatic decline. Strongest action: a hold that says the money has not left, a 30-minute human review, a release request and an appeal.
- False warnings concentrate on alarming-but-legitimate payments: 3.29% vs 0.21% on ordinary traffic — measured, not hidden.
- Bias: worst segment false-warning rate 3.43x the overall rate; 1 segment(s) over the 2x tolerance.
- Misuse tests in CI: rate-limited scoring with bands only (no score to the client); fresh-account complaints ignored; complaints alone cannot hold a payee; analyst evidence access audited.
- Privacy: salted-HMAC ids, no message content, retention TTL, consented signals stay missing (never zero) without consent; DPDP-style purpose limitation and minimisation.



Adoption, integration and the 48-hour plan

- Where it runs: PSP / issuer bank, as an approval-screen SDK hook plus a scoring API (FastAPI, single model bundle, run id on every response). Owner: the fraud-risk team.
- Rollout: shadow mode -> A1 nudges -> A2 warnings with cooling-off -> A3 holds sized to analyst capacity.
- Measured latency (laptop, loopback): stored payment p95 61 ms; online event with feature recomputation p95 216 ms.
- Capacity: holds 1.74 vs analyst capacity 1.54 per 1,000 payments — over capacity on the test window; a capacity guard (overflow holds become warnings) is finale task 3.
- Already built and tested: generator, pipeline, API, offline console, Scam Studio, replay bundle.
- Finale, 48 h:
 - 1. Judges compose a scam live (variant x evasion x segment) and watch where Citadel fires
 - 2. Add a new script to the grammar; measure it as unseen
 - 3. Capacity guard + per-segment thresholds
 - 4. Hindi/English customer screens with senior-friendly large text
 - 5. 3 / 5 / 8-minute demo, offline replay as fallback

Appendix A — Known limitations (generated)

- Holds exceed analyst capacity on the test window (1.74 vs 1.54 per 1,000): thresholds were fitted on an earlier slice and prevalence drifted. Mitigation for the finale: a capacity guard that downgrades overflow holds to A2 warnings.
- Synthetic-data ceiling. A time-forward probe on the derived features reaches recall 0.836 at 0.5% FPR (flag threshold 0.92); deployed systems on real data typically sit at 0.5-0.85. Every number here is an UPPER BOUND on real-world performance.
- Weakest variant: V4 — recall at A2+ 0.273 [0.163, 0.418] on 44 payments.
- Generalisation gap (withheld_variant_V4): recall 0.273 vs seen (gap 0.555, retained 0.330) on 44 payments.
- Generalisation gap (withheld_evasion_signal_suppression): recall 0.875 vs seen (gap -0.097, retained 1.124) on 8 payments.
- Layer with no measured benefit: '+ L0 rules as features' — delta PR-AUC 0.000 [0.000, 0.000] (no measured effect).
- Label scarcity: trained only on labels visible by the training cutoff, PR-AUC is 0.548 (oracle-label model in the headline). trained on 257 visible positives vs 818 oracle; evaluated on oracle truth.
- Fusion adds no measured lift over L1 alone: deployed minus L1-alone recall at 0.5% FPR 0.009 [-0.014, 0.024] (no measured effect). The L2 payee channel is kept for readable payee evidence, not for lift.
- Cost sensitivity: net saving share ranges 0.238-0.773 across the assumption sweep; every rupee figure is simulator-internal.

Appendix B — Disclosure

- Data: 100% synthetic from the Citadel generator; 398,531 payments, 25,001 customers, 898 scam episodes; seed 7, config a2f4e9895fd6064b, library 88370429fa1e1309, run 3a888efe3099. No real bank, customer or platform data; nothing scraped.
- Models: scikit-learn HistGradientBoosting, LogisticRegression, IsolationForest (candidate), isotonic calibration. No pretrained models; no LLM in the scoring path.
- Reused components: none; all code written for Citadel. Libraries pinned in requirements.txt.
- AI assistance: code, configuration and documentation written with an AI coding assistant under the team's direction; all numbers come from the pipeline and are checked against numbers_index.md.
- Assumptions (labelled, swept): cost model, heed rates, label latency, analyst capacity, signal observability.
- Not collected: message/call content, contact names, location, the lure, raw account numbers.